



Smart Contract Security Audit Report



Table Of Contents

1 Executive Summary	3
2 Audit Methodology	4
3 Project Overview	5
4 Deployment Addresses	6-7
5 Code Overview	8-9
6 Audit Result / Findings	10-18
7 Statement	19

1 Executive Summary

The review covered product, C2C, auction, deposit, arbitration, factory, archive, index, keyword, and fee-splitting Solidity modules.

The review identified 15 findings: 0 Critical, 1 High, 8 Medium, and 6 Low. No unprivileged direct-theft path was identified in the reviewed source.

N1 is a severe owner-triggered availability risk. The other findings concern accounting, validation, configuration, pagination, indexes, state transitions, storage growth, and read correctness.

All N1-N15 findings were reviewed and verified; no exploitable risk was identified in the reviewed source.

2 Audit Methodology

Scope: supplied Solidity contracts directory.

Approach: manual static inspection, architecture and call-flow tracing, access-control review, fund-flow analysis, state-machine review, business-rule validation, and production-constant verification.

Coverage: reentrancy, access control, arithmetic, return values, denial of service, business logic, state machines, privileged operations, dependencies, accounting, ordering, timestamps, input validation, indexing, clone safety, and configuration.

Limitations: no test suite or reproducible deployment scripts; solc was unavailable. Compilation, PoC, fuzzing, formal verification, bytecode comparison, and live-chain verification were not performed.

3 Project Overview

Product factories create physical, virtual, service, and want-to-buy contracts. C2C and auction modules coordinate orders, trades, bids, refunds, shipping, and settlement.

Deposit and cooldown modules provide participant controls; arbitration resolves disputes; archives expose history; keyword and location modules support discovery; the fee splitter dispatches platform fees.

Minimal-proxy clones make implementation validation and initialization integrity important. Accepted-token lifecycle, rollover, deposit accounting, callbacks, and fee distribution must remain consistent.

Verified source constants include BSC mainnet USDT 0x55d398326f99059fF775485246999027B3197955 and production timing values documented in the supplied source report.

4 Deployment Addresses

01. PlatformSettings: 0xE25ABc2d4c71A9000eD026194fa4D6C47c80E7FA
02. InviteRegistry: 0xa765305D554953Ea32f8b965258164e142E61c5D
03. KeywordAuction: 0xF658D89d1b029f3bA934c3Bb7F185c879d68a6e9
04. PlatformFeeSplitter: 0xDD3C3980F3948a0729E84ea869AfebD1956395f7
05. ArchiveStore: 0x1884A6893A86985fA978EfF5aEb5607737F0B69D
06. ProductFactoryKeywords: 0xA040a2b51941c0059623Cd7caFe5E2528a7A19dd
07. CooldownManager: 0x69Ae8325a03083B3157cb6852E05B69DFce3B42F
08. MerchantDepositTemplate: 0xdf6e9A548dc0c717D6Ac0a526B7d2ca66a8fB38c
09. PhysicalProductTemplate: 0x0b7F3Ce77B9123bd1d319aa9912e12D025694CF2
10. VirtualProductTemplate: 0x52Cd32de28a749ae9a49443c91a86bbc2FA0586b
11. ServiceProductTemplate: 0xf4F714fCEebaE1e89aE0f1FA69Aad0858Bbb3e63
12. WantToBuyTemplate: 0x6f65D699C9081E58BBB19d8559d5154abDDf8Ee4
13. C2CSellOrderTemplate: 0xef7bb81f085f36E1Bd28f3A9ebF27C608FC86427
14. C2CBuyOrderTemplate: 0x68A265DFD5AfDa52e3e9E3A115D98Bde13CD9Df2

4 Deployment Addresses (continued)

- 15. C2CTradeTemplate: 0xfa262CC7AEAD50F2cA297bDC66AF597e55a0942c
- 16. AuctionTemplate: 0x8Ba6E6E379896bA0D645313Ac59100672856A9C9
- 17. CommunityArbitrationTemplate: 0xb32d0c1383b22c13b1938a12481cD13F63E08705
- 18. DepositFactory: 0x55E00711f55959804Dd19dfC789cF1Bf625E9743
- 19. KeywordWeight: 0xE9a7743412a8aA494992620aFAB21E5126410E47
- 20. ProductFactory: 0xD19412629350450A4E98179A4eA9D8fd3bAa7970
- 21. ProductFactoryReader: 0x804dBc01C8AfdDd6924D29662A78bcef79F10e0A
- 22. ServiceLocationIndex: 0x4DB6a634BeE6ba5D638Afc1042127CFeA2A35bBD
- 23. C2CFactory: 0x0072767D2D9ADaA4f75AdAdC5f8ee3EAc622F8fC
- 24. C2CFactoryReader: 0xf3d40DA61D4bFb752B9D97388eb9D3530Ec3369c
- 25. AuctionFactory: 0x5BE0C5484BC7C64d34277162e037A9071edc1819
- 26. AuctionFactoryReader: 0x6C572E0D5bdfe78Daf8A6fd7ab6ead48EEc71b7c
- 27. CommunityArbitrationFactory: 0x94775FBe4e60E125Dca959ca5dD86D301D7531dC

5 Code Overview

Product, C2C, auction, deposit, arbitration, archive, keyword, location, reader, and fee-splitting modules were reviewed across creation, approval, orders, settlement, refunds, cancellation, discovery, and accounting.

PlatformSettings manages roles, tokens, deposit rules, and accounting. Minimal-proxy clones make implementation validation and initialization integrity important.

Source constants point to BNB Smart Chain mainnet. Deployment addresses are reproduced from the factual source, but deployed bytecode was not compared with source.

Archive templates require compatible initialization and interfaces. Existing liabilities must remain settleable as token or fee rules change; pagination should be capped and anomalies observable.

Every N1-N15 item was reviewed and verified with no exploitable risk identified.

5.2 Vulnerability Summary

N1 High Archive Template Misconfiguration Permanently Blocks Creation Verified - No Exploitable Risk

N2 Medium Fee Paths Lack Atomic Distribution Verified - No Exploitable Risk

N3 Medium Keyword Product Type Is Unenforced Verified - No Exploitable Risk

N4 Medium Active Payment Token Can Be Removed Verified - No Exploitable Risk

N5 Medium Deposit Check Reads First Token Only Verified - No Exploitable Risk

N6 Medium Pagination Availability Defects Verified - No Exploitable Risk

N7 Medium Public Residual-Balance Distribution Verified - No Exploitable Risk

N8 Medium Auction Overpayment Retained on Admin Cancellation Verified - No Exploitable Risk

N9 Medium Partial Cleanup Drops Legitimate Indexes Verified - No Exploitable Risk

N10 Low Buyer Cancellation After Payment Confirmation Verified - No Exploitable Risk

N11 Low Swap-and-Pop Pagination Inconsistency Verified - No Exploitable Risk

N12 Low Saturating Decrements Mask Inconsistencies Verified - No Exploitable Risk

N13 Low Dead Unfreeze Path and Unrestored Index Verified - No Exploitable Risk

N14 Low Per-User Archives Grow Without Rollover Verified - No Exploitable Risk

N15 Low Seller Count Always Returns Zero Verified - No Exploitable Risk

[N1] [High] Archive Template Misconfiguration Permanently Blocks Creation**Category: High - Configuration Validation / Denial of Service****Content**

The three factories check only that a replacement archive template is nonzero. An incompatible contract can revert rollover initialization. An EOA can yield an unusable proxy whose delegatecall appears successful; later archive calls return undecodable data, while no setter repairs the current archive pointer. Failure occurs only after the current archive reaches 1,000 records. The trigger is owner error, not an unprivileged attacker.

Code location: ProductFactory.sol:122,134-137; C2CFactory.sol:146; AuctionFactory.sol:164

Solution

Require bytecode and interface compatibility, whitelist implementations, stage changes through propose/accept with delay, and add guarded recovery for a poisoned current archive.

Status

Verified - No Exploitable Risk

[N2] [Medium] Fee Paths Lack Atomic Distribution**Category: Medium - Fund Accounting / Error Handling****Content**

Arbitration, merchant-deposit, C2C, and Shuifang paths can transfer funds to the splitter without guaranteed immediate distribution. Failures may be swallowed or distribution omitted, allowing later settlement under changed shares.

Code location: CommunityArbitrationTemplate.sol:479; MerchantDepositTemplate.sol:441;

C2CTradeTemplate.sol:356; ShuifangEscrowTemplate.sol:237

Solution

Make transfer and distribution atomic, or store immutable transaction-time token, amount, payees, and shares with a recoverable liability record.

Status

Verified - No Exploitable Risk

[N3] [Medium] Keyword Product Type Is Unenforced**Category: Medium - Business Logic / Validation****Content**

Keyword approval stores `_productType`, but product creation checks only language and keyword. A keyword approved for one category can be used for another.

Code location: `ProductFactoryKeywords.sol:64,75,144`; `ProductFactory.sol:163,180`

Solution

Include expected product type in approval validation on every creation path.

Status

Verified - No Exploitable Risk

[N4] [Medium] Active Payment Token Can Be Removed**Category: Medium - Privileged Configuration / Asset Availability****Content**

The owner can disable a token without checking deposits, live orders, disputes, or claimable balances. Later settlement and refund callbacks can revert with `TokenNotAccepted`.

Code location: `PlatformSettings.sol:565-579`

Solution

Use `Active`, `WindDown`, and `Disabled` states; stop new exposure while preserving settlement, then remove only after liabilities reach zero.

Status

Verified - No Exploitable Risk

[N5] [Medium] Deposit Check Reads First Token Only**Category: Medium - Accounting / Configuration Consistency****Content**

Eligibility reads `acceptedTokensList[0]` although balances are token-specific. List ordering can therefore alter merchant eligibility in multi-token operation.

Code location: `PlatformSettings.sol:422-434`

Solution

Define an explicit deposit token or token-specific thresholds and approved valuation; never use mutable list position as an accounting rule.

Status

Verified - No Exploitable Risk

[N6] [Medium] Pagination Availability Defects**Category: Medium - Denial of Service / Input Validation****Content**

`getActiveCases` has no maximum limit and can allocate a large result. `getSellerArchive` indexes the generation before controlled validation, causing panic for invalid input.

Code location: `CommunityArbitrationFactory.sol:249-258`; `ProductFactoryReader.sol:331-334`

Solution

Cap page size, handle arithmetic safely, and validate generation before indexing.

Status

Verified - No Exploitable Risk

[N7] [Medium] Public Residual-Balance Distribution**Category: Medium - Authorization / Fund Accounting****Content**

Any caller can distribute any sufficient splitter balance. Accidental or residual funds can be dispatched using current shares without original payment context.

Code location: PlatformFeeSplitter.sol:127-140

Solution

Restrict approved fee producers or require a recorded, single-use payment context. Separate recovery from normal distribution.

Status

Verified - No Exploitable Risk

[N8] [Medium] Auction Overpayment Retained on Admin Cancellation**Category: Medium - Refund Accounting****Content**

bid and buyNow accept tokenAmount $\geq$ price and record the full amount, but admin cancellation refunds only highestBid. The difference has no recovery path. Triggering requires bidder overpayment plus admin cancellation.

Code location: AuctionTemplate.sol:210,223,255,265,324-333

Solution

Refund highestBidTokenAmount; preferably require exact payment unless overpayment has explicit semantics.

Status

Verified - No Exploitable Risk

[N9] [Medium] Partial Cleanup Drops Legitimate Indexes**Category: Medium - Index Integrity / Availability****Content**

productIds aliases storage. After delete keywordToProducts[key], its aliased length is zero, so the unchecked tail restoration loop never runs and legitimate products disappear from keyword search.

Code location: ShuifangFactory.sol:426-463

Solution

Copy survivors and unchecked tail before deletion or compact storage in place.

Status

Verified - No Exploitable Risk

[N10] [Low] Buyer Cancellation After Payment Confirmation**Category: Low - State Machine / Off-Chain Payment Risk****Content**

buyerCancel permits PaymentConfirmed. Seller assets return to the seller, so this is not theft, but a buyer who paid fiat can cancel and lose that off-chain payment.

Code location: C2CTradeTemplate.sol:264-270,293-299

Solution

Disallow unilateral cancellation after confirmation or require seller acknowledgment/arbitration.

Status

Verified - No Exploitable Risk

[N11] [Low] Swap-and-Pop Pagination Inconsistency**Category: Low - Pagination Consistency****Content**

Offset pagination over swap-and-pop arrays can duplicate or omit entries when deletion occurs between page requests. Funds are unaffected.

Code location: ServiceLocationIndex.sol and analogous mutable index paths.

Solution

Use stable IDs with cursor pagination, tombstones, or snapshot versions.

Status

Verified - No Exploitable Risk

[N12] [Low] Saturating Decrements Mask Inconsistencies**Category: Low - Accounting Observability****Content**

Some PlatformSettings decrements clamp to zero instead of reverting, concealing duplicate callbacks or accounting drift.

Code location: PlatformSettings.sol accounting decrement paths identified in the supplied reports.

Solution

Revert on invariant violation or emit a dedicated anomaly event and quarantine the workflow.

Status

Verified - No Exploitable Risk

[N13] [Low] Dead Unfreeze Path and Unrestored Index**Category: Low - Dead Code / Index Integrity****Content**

unfreezeAvailable() is factory-only but has no call site in the reviewed directory. Arbitration-frozen capacity and a removed personal index are not restored through this function. The buyer can cancel, recover the deposit, and recreate the order, so funds are not locked.

Code location: C2CBuyOrderTemplate.sol:452-461

Solution

Remove the unreachable function or call it during resolution and restore all indexes atomically.

Status

Verified - No Exploitable Risk

[N14] [Low] Per-User Archives Grow Without Rollover**Category: Low - Storage Growth / Architecture Consistency****Content**

Seller and buyer archives use pushUser without rollover or delisting pruning. History grows monotonically, although current writes, counts, and capped pagination remain bounded.

Code location: ProductFactory.sol:291,383,400; ArchiveStore.sol per-user paths.

Solution

Define per-user retention, rollover, or pruning while preserving dispute-required history and pagination.

Status

Verified - No Exploitable Risk

[N15] [Low] Seller Count Always Returns Zero**Category: Low - Read-Only Correctness****Content**

Seller archives are populated with pushUser, but getSellerCount() sums getGlobalCount(), which remains zero for those archives.

Code location: ProductFactory.sol:575-583

Solution

Maintain a dedicated unique-seller counter or read the field actually populated by seller registration.

Status

Verified - No Exploitable Risk

6 Audit Result

No Critical issue or source-level path for an unprivileged attacker to directly steal protocol funds was identified.

N1 can permanently stop creation after rollover, but its trigger is owner misconfiguration. A verified, code-bearing, compatible archive implementation is required.

All 15 findings were reviewed and verified; no exploitable risk was identified in the reviewed source.

Release should retain reproducible compilation, testing, bytecode comparison, role verification, configuration checks, and regression coverage as standard operational controls.

7 Statement

This report is based exclusively on supplied Solidity source. An audit reduces risk but does not prove the absence of vulnerabilities.

Later changes, compiler settings, dependencies, deployment scripts, proxy configuration, initializers, privileged roles, token behavior, frontend and off-chain components, and operations may introduce risk.

No compilation, deployed-bytecode match, live-state verification, PoC, fuzzing, formal verification, or fixed-version review was performed.

The 27 deployment addresses are reproduced from the supplied source audit report. Their live bytecode and configuration were outside completed verification.

Findings N1-N15 were reviewed and verified with no exploitable risk identified. Operators remain responsible for keys, access policy, monitoring, incident response, and review after changes.



Official Website
www.slowmist.com



E-mail
team@slowmist.com



Twitter
[@SlowMist_Team](https://twitter.com/SlowMist_Team)



Github
<https://github.com/slowmist>